

Bachelor's Thesis Proposal

Purpose-based Access Control for Relational Database Management System

Assessor: Dr. Hoang Nguyen
Co-assessor: To be decided

1 Motivation

Ensuring that software systems, especially web applications, comply with privacy requirements is a complex and critical challenge. On the one hand, it is complex because laws, such as the GDPR [1], impose strict requirements on how organizations handle (personal) data but offer limited guidance on concrete technical solutions. On the other hand, it is critical because failing to comply with these requirements can result in substantial financial penalties.

Model-driven privacy [2] (MDP) is a software development methodology in which privacy requirements are specified as models, and enforcement mechanisms are generated automatically via model transformations. MDP enables developers to specify three interconnected declarative models: a data model describing the state space of the system, a security model capturing fine-grained access control requirements, and a privacy model expressing data protection requirements, which is a particularly challenging class of privacy requirements. From these models, our methodology automatically generates a web application together with enforcement mechanisms that make it security- and privacy-aware by design.

In practice, the data is ultimately stored at the data layer. Furthermore, modern database management systems already offer native mechanisms for protecting the data. For example, using views, row-level security policies, and privilege grants, as far as confidentiality is concerned.

2 Objective

In this thesis, we focus on preserving the *confidentiality* of personal data from being accessed in software systems that use a relational database management system underneath.

The high-level objective of this thesis is to apply the idea of model-driven privacy to generate or rewrite SQL queries into ones that are privacy-aware, i.e., queries that automatically enforce privacy policies.

More specifically, given a privacy model, in this thesis, our goal is to generate SQL enforcement artifacts: either (a) a set of SQL *views* that expose exactly the authorized subset of personal data to each data subject, or (b) *authorization checks*. The generated artifacts should guarantee that any read performed through them returns only the data that the subject is authorized to see.

3 Tasks

1. Study the existing MDP approach and relational database management system for read access control.
2. Define a model transformation that takes the privacy model and generates SQL views and/or SQL authorization checks.
3. Implement the model transformation targeting a specific technology (e.g., MySQL).
4. Validate the approach on a case-study database, checking that reads reveal only authorized data and assessing the performance overhead.
5. Document the design, implementation, and evaluation in the final report.

4 Deliverables

The following deliverables are due at the end of the project:

Final report Please have a look at the submission requirements in the following section. The final report should consist of an introduction, a (theoretical) background section, sections describing the work packages and their outcomes, and a conclusion. The report must be written in English.

Source code Complete, documented source code with a reproducible evaluation.

Presentation At the end of the thesis, a 20 minute presentation must be given in a thesis defense seminar. It should give an overview and discuss the most important highlights of the work.

References

- [1] European Parliament and Council. Regulation (EU) 2016/679, 2016. <https://eur-lex.europa.eu/eli/reg/2016/679/oj>.
- [2] Srdan Krstic, Hoang Nguyen Phuoc Bao, and David A. Basin. Model-driven privacy. *Proc. Priv. Enhancing Technol.*, 2024(1):314–329, 2024.

Thesis Submission Guidelines

Submission Requirements

- **Soft copy:** Submit via email to cse@vgu.edu.vn.
- **Hard copies:** Submit two (02) printed copies to the CSE Office (Room 511, Cluster 3).
- The Thesis cover requires at least 3 days to complete. Please make sure to prepare it at the photocopy shop as soon as possible.

Submission Timeline

- You may submit your Final Thesis Report (soft + hard) up to one week before the deadline.
- Early or late submissions will **NOT** be accepted.

Thesis Title Changes

- If you wish to change your Thesis title, please submit a “Request for Changing Thesis Title” by yourself.
- The request must be sent to us within the first four weeks of the preparation period.

Additional Resources

- Required forms and the Thesis template can be found at [Thesis Resources Link](#).
- Please read the Thesis Guidelines carefully.

Intellectual Property

Project: Purpose-based Access Control for Relational Database Management System

Assessor: _____

Student: _____

The student participates in this project at Vietnamese-German University (VGU) as a collaborator under the supervision of the assessor in the course of their studies towards the degree named above. The results produced during the collaboration, including the deliverables listed in Section 4, in particular the source code and the final report, constitute the “Research Results” and are governed by the following terms:

Confidentiality The student keeps the Research Results, together with any other information from the supervising research group at VGU that is declared confidential, confidential. This obligation persists until the student is informed that the intellectual property rights have been protected (e.g. through patent applications or other adequate measures) or that no protection is sought, and in no case for longer than twelve (12) months after completion of the collaboration.

Assignment of rights The student assigns to VGU their rights to the Research Results, including inventions and works protected by copyright. In particular, all rights to the commercial exploitation of the Research Results are ceded to VGU.

Patent cooperation If a patent application is filed for an invention based on the Research Results, the student provides all necessary signatures and remains available to support the application process, e.g. to respond to questions from patent examiners.

By signing below, the parties agree to the terms set out above.

Vietnamese-German University (VGU)

Place, Date

The assessor

The Student

Place, Date

The student